

Security Review

Cantina Managed

SKY: LZ SSR ORACLE INIT

Cantina Managed review by:

Christoph Michel, Lead Security Researcher

M4rio.eth, Lead Security Researcher



September 4, 2026



Contents

1	Introduction	2
1.1	About Cantina	2
1.2	Disclaimer	2
1.3	Risk assessment	2
1.3.1	Severity Classification	2
2	Security Review Summary	3
3	Findings	4
3.1	Informational	4
3.1.1	Activating SSR0racle can change CCIPDVNAdapter allowlist semantics	4
3.1.2	SSR activation accepts an executor message limit below the required payload size	4



1 Introduction

1.1 About Cantina

Cantina is a security platform that pairs a world-class network of security researchers with agentic AI to help teams building onchain find and fix real risk. Through managed reviews, competitions, and bounties, Cantina secures protocols before vulnerabilities can be exploited.

Learn more at cantina.security

1.2 Disclaimer

Cantina Managed provides a detailed evaluation of the security posture of the code at a particular moment based on the information available at the time of the review. While Cantina Managed endeavors to identify and disclose all potential security issues, it cannot guarantee that every vulnerability will be detected or that the code will be entirely secure against all possible attacks. The assessment is conducted based on the specific commit and version of the code provided. Any subsequent modifications to the code may introduce new vulnerabilities that were absent during the initial review. Therefore, any changes made to the code require a new security review to ensure that the code remains secure. Please be advised that the Cantina Managed security review is not a replacement for continuous security measures such as penetration testing, vulnerability scanning, and regular code reviews.

1.3 Risk assessment

Severity level	Impact: High	Impact: Medium	Impact: Low
Likelihood: high	Critical	High	Medium
Likelihood: medium	High	Medium	Low
Likelihood: low	Medium	Low	Low

1.3.1 Severity Classification

The severity of security issues found during the security review is categorized based on the above table. Critical findings have a high likelihood of being exploited and must be addressed immediately. High findings are almost certain to occur, easy to perform, or not easy but highly incentivized thus must be fixed as soon as possible.

Medium findings are conditionally possible or incentivized but are still relatively likely to occur and should be addressed. Low findings are a rare combination of circumstances to exploit, or offer little to no incentive to exploit but are recommended to be addressed.

Lastly, some findings might represent objective improvements that should be addressed but do not impact the project's overall security (Gas and Informational findings).



2 Security Review Summary

From Aug 21st to Aug 23rd the Cantina team conducted a review of [lz-init-lib](#) on commit hash [e717ef6c](#). The team identified a total of **2** issues:

Issues Found

Severity	Count	Fixed	Acknowledged
Critical Risk	0	0	0
High Risk	0	0	0
Medium Risk	0	0	0
Low Risk	0	0	0
Gas Optimizations	0	0	0
Informational	2	0	2
Total	2	0	2

The Cantina Managed team reviewed Sky's [lz-init-lib](#) holistically on commit hash [70d6e028](#) and concluded that all findings were addressed and no new vulnerabilities were identified.

3 Findings

3.1 Informational

3.1.1 Activating `SSROracle` can change `CCIPDVNAdapter` allowlist semantics

Severity: Informational.

Context: `LZInit.sol#L334`.

Description: If the `CCIPDVNAdapter` has `allowlistSize == 0` when activating the `SSROracle` :

1. The SSR forwarder was already active before the call and didn't need an explicit activation, allowing users to refresh the oracle before activation.
2. If the adapter intentionally uses open-to-all semantics and serves other OApps, adding an allowlist entry changes those semantics and can lock out the other OApps.

Recommendation: Always use explicit allowlists for `CCIPDVNAdapter` instances. Ensure that an early `SSROracle` refresh before `activate` is safe, or initialize the adapter with a non-zero `allowlistSize` .

Sky: Acknowledged.

Cantina Managed: Acknowledged.

3.1.2 SSR activation accepts an executor message limit below the required payload size

Severity: Informational.

Context: `LZInit.sol#L522-L525`.

Description: If `cfg.execCfg.maxMessageSize` is set to a non-zero value below `100` , `_verifyForwarderConfig` still succeeds as long as the configured executor settings match `cfg.execCfg` . The SSR forwarder's LayerZero message is always 100 bytes:

1. `refresh()` encodes `setSUSDSData(SUSDSData)` using `abi.encodeCall`.
2. `SUSDSData` contains three static fields, `uint96` , `uint120` , and `uint40` (see).
3. ABI encoding therefore produces `4 + 32 + 32 + 32 = 100` bytes.

As a result, `activateSsrForwarder` can complete and grant the forwarder its CCIP allowlist role, while subsequent `quote()` and `refresh()` calls revert because the LayerZero executor rejects the 100-byte message as exceeding `maxMessageSize` .

The `_verifyOftConfig` as well is missing this check.

Recommendation: Require `cfg.execCfg.maxMessageSize` checks or both `_verifyForwarderConfig` and `_verifyOftConfig` .

```
uint32 constant SSR_PAYLOAD_SIZE = 4 + 3 * 32; //
↳ setSUSDSData((uint96,uint120,uint40)), always 100 bytes
uint32 constant OFT_SEND_MSG_SIZE = 32 + 8; // OFTMsgCodec: sendTo + amountSD;
↳ compose adds 32 + composeMsg.length (unbounded)
//...
// _verifyForwarderConfig
require(cfg.execCfg.maxMessageSize >= SSR_PAYLOAD_SIZE,
↳ "LZInit/exec-max-msg-size");
// _verifyOftConfig
require(cfg.execCfg.maxMessageSize >= OFT_SEND_MSG_SIZE,
↳ "LZInit/exec-max-msg-size");
```

Sky: Acknowledged.

Cantina Managed: Acknowledged.